

SIMATS ENGINEERING

ASSESSMENT TOOL 1

Name	SHAIK REEHAN
Register Number	192565071
Date	
Time	1hr

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA60

COURSE OUTCOME COVERED

CO5: *Implement database operations using query processing, optimization, and transaction management to ensure consistency and reliability. (BL3, BL4)*

Activity Tool : Constraint-Based Problem Solving (High)

Assessment Tool Weightage:40%

Code of Conduct:

I _____shaikreehan.192565071_____ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Shaik Reehan

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Post-Incident Review and Timeline Reconstruction	25%	Thoroughly reconstructs the incident timeline using relevant logs, alerts, tickets, and evidence and clearly identifies key events and response actions.	Reconstructs the major incident timeline and identifies key events with minor omissions.	Provides a basic timeline but misses important events or sequence details.	Unable to reconstruct the incident timeline accurately.
Root Cause Analysis and Contributing Factors	25%	Accurately identifies the root cause, contributing factors, security weaknesses, and underlying issues using strong evidence and logical analysis.	Identifies the main root cause and contributing factors with minor gaps in analysis.	Identifies a probable cause but provides limited analysis of contributing factors.	Unable to identify the root cause or supporting factors.
Lessons Learned and Impact Assessment	20%	Clearly evaluates what worked and failed during the incident, assesses technical and business impact, and derives meaningful lessons learned.	Provides a reasonable assessment of impact and lessons learned with minor omissions.	Provides basic lessons learned and limited impact assessment.	Fails to identify meaningful lessons learned or assess the incident impact.
Recommendations and Future Prevention	15%	Provides specific, practical, and prioritized recommendations covering security controls, policies, processes, monitoring, and prevention of recurrence.	Provides relevant recommendations with minor gaps in prioritization or implementation details.	Provides general recommendations with limited connection to identified weaknesses.	Provides few or inappropriate recommendations for future prevention.
Documentation, Final Report, and Presentation	15%	Provides a clear, professional final report with evidence, findings, timeline, root cause, lessons learned, recommendations, and well-structured presentation.	Report is well organized and contains most required findings with minor presentation issues.	Report is partially organized with limited evidence, analysis, or supporting details.	Report is incomplete, poorly organized, and lacks clear findings or supporting evidence.

1. Policy Updates and Continuous Improvement

Introduction

After a major cybersecurity incident, a post-incident investigation should not end with restoring systems. The organization must analyze what happened, identify weaknesses, update security policies, and implement continuous improvement measures. In this case, weaknesses were identified in **password policies, access controls, patch management, and incident escalation procedures**. As a cybersecurity consultant, I would use the investigation findings to improve security controls through a structured **Post-Incident Review (PIR)** and **Root Cause Analysis (RCA)** process.

A. Post-Incident Review and Timeline Reconstruction

The first step is to reconstruct the complete incident timeline using available evidence such as:

- Authentication and login logs
- Firewall and IDS/IPS alerts
- Endpoint detection logs
- Server and application logs
- Vulnerability-scan reports
- Help-desk tickets
- Incident-response records
- Email/security alerts
- Administrator activity logs

Example Incident Timeline

Time	Event	Evidence	Response
08:30	Attacker obtains compromised credentials	Authentication logs	No immediate action
09:00	Unauthorized login occurs	VPN/server logs	Login remains undetected
09:30	Privileged access is obtained	Access-control logs	No privilege escalation alert
10:00	Unpatched system is exploited	Vulnerability and system logs	System becomes compromised
10:30	Suspicious network activity begins	Firewall/IDS logs	Security team receives alert
11:00	Incident is escalated	SOC/incident ticket	Investigation begins
12:00	Compromised accounts and systems identified	EDR and authentication logs	Accounts disabled
13:00	Affected systems isolated	Network/EDR records	Containment completed

Time	Event	Evidence	Response
15:00	Vulnerabilities patched and credentials reset	Patch and IAM records	Recovery begins
17:00	Systems restored and monitored	Recovery logs	Incident closed

This timeline helps determine **where detection failed, how long the attacker remained in the environment, and whether response procedures were followed correctly.**

B. Root Cause Analysis

The investigation should distinguish between the **root cause** and **contributing factors**.

Root Cause

The primary root cause was inadequate security controls that allowed compromised credentials and an unpatched system to be used for unauthorized access.

Contributing Factors

1. **Weak password policy**
 - Passwords may have been too weak or reused.
 - Multi-factor authentication may not have been enforced for sensitive accounts.
 - Password rotation and compromised-password detection were insufficient.
2. **Poor access control**
 - Users may have had excessive privileges.
 - Privileged accounts were not sufficiently protected.
 - Least-privilege principles were not consistently applied.
3. **Weak patch management**
 - Critical vulnerabilities were not patched within the required timeframe.
 - Asset and vulnerability inventories were incomplete.
 - Patch compliance was not continuously monitored.
4. **Delayed incident escalation**
 - Escalation thresholds were unclear.
 - Employees or SOC analysts were uncertain about when to escalate an alert.
 - Communication between technical teams and management was slow.
5. **Insufficient monitoring**
 - Suspicious authentication and privilege changes were not detected quickly.
 - Security alerts were not adequately correlated.

C. Lessons Learned and Impact Assessment

The post-incident review should document both successful and unsuccessful actions.

What Worked

- Security monitoring eventually detected suspicious activity.
- The incident-response team was able to isolate affected systems.
- Compromised accounts were disabled.

- Systems were eventually patched and restored.

What Failed

- Initial unauthorized access was not detected quickly.
- Password controls were insufficient.
- Excessive privileges increased the potential impact.
- Critical patches were delayed.
- Escalation procedures were unclear.

Business and Technical Impact

The incident may result in:

- Unauthorized access to organizational systems
- Data exposure or loss
- Service interruption
- Financial losses
- Recovery and investigation costs
- Legal or regulatory consequences
- Reputational damage
- Loss of customer trust

The impact should be quantified wherever possible, including downtime, affected systems, number of accounts, records exposed, recovery cost, and business hours lost.

D. Policy Updates

The findings should be converted into specific policy changes.

1. Password Policy

The organization should:

- Require strong and unique passwords.
- Enforce multi-factor authentication for privileged and remote access.
- Block known compromised passwords.
- Implement account lockout/risk-based authentication where appropriate.
- Require secure password management for administrators.
- Review service-account credentials regularly.

2. Access-Control Policy

The organization should implement:

- Least-privilege access.
- Role-Based Access Control (RBAC).
- Privileged Access Management (PAM).
- Regular access reviews.

- Immediate removal of unnecessary accounts.
- Strong authentication for administrative operations.

3. Patch Management Policy

A formal patch-management policy should define:

- Criticality-based patch deadlines.
- Regular vulnerability scanning.
- Asset inventory requirements.
- Patch compliance targets.
- Emergency patch procedures.
- Exceptions and their approval process.

For example, critical vulnerabilities should have a much shorter remediation deadline than low-risk vulnerabilities.

4. Incident Escalation Policy

The organization should establish:

- Clearly defined severity levels.
- Escalation time limits.
- Roles and responsibilities.
- SOC-to-management communication procedures.
- Contact and backup escalation paths.
- Criteria for activating the incident-response team.

E. Continuous Improvement

Security improvement should follow a continuous cycle:

Incident → Investigation → Root Cause Analysis → Lessons Learned → Policy Update → Control Implementation → Testing → Monitoring → Review

The organization should maintain a corrective-action register containing:

Finding	Risk	Corrective Action	Owner	Priority	Deadline	Status
Weak passwords	High	Enforce MFA and stronger passwords	IAM Team	Critical	30 days	Open
Excessive privileges	High	Implement RBAC/PAM	Security Team	Critical	45 days	Open
Unpatched systems	High	Improve patch-management process	IT Team	Critical	30 days	Open
Delayed escalation	Medium/High	Update escalation matrix	SOC	High	15 days	Open

Follow-up audits and security assessments should verify that corrective actions have actually been implemented.

2. Incident Response KPIs and Governance

Introduction

Senior management needs measurable indicators to determine whether the organization's incident-response capability is improving. **Key Performance Indicators (KPIs)** provide objective evidence about detection, response, containment, recovery, and recurrence.

A. Mean Time to Detect (MTTD)

MTTD = Total time taken to detect incidents ÷ Number of incidents

MTTD measures how quickly the organization identifies a security incident after it begins.

Example

If three incidents took 20, 30, and 40 minutes to detect:

MTTD = (20 + 30 + 40) / 3 = 30 minutes

A decreasing MTTD indicates that monitoring, alerting, and detection capabilities are improving.

B. Mean Time to Respond (MTTR)

MTTR measures the average time required for the security team to begin taking meaningful action after an incident is detected.

MTTR = Total response time ÷ Number of incidents

A lower MTTR generally indicates better incident-response efficiency.

C. Incident Resolution Time

Incident resolution time measures the total time from incident identification until the incident is fully resolved.

It can include:

Detection → Analysis → Containment → Eradication → Recovery → Closure

For example, if an incident is detected at 10:00 and completely resolved at 16:00:

Incident Resolution Time = 6 hours

Management can track whether resolution times are improving over time.

D. Escalation Rate

Escalation rate measures the percentage of incidents that require escalation to a higher-level security team or management.

$$\text{Escalation Rate} = (\text{Number of escalated incidents} \div \text{Total incidents}) \times 100$$

For example, if 10 out of 100 incidents require escalation:

$$\text{Escalation Rate} = (10/100) \times 100 = 10\%$$

A very high rate may indicate that frontline analysts lack sufficient capability or that alert severity rules are poorly configured. A very low rate may also require investigation if serious incidents are not being escalated correctly.

E. Recurring Incident Rate

Recurring incidents show whether previously identified weaknesses have actually been corrected.

$$\text{Recurring Incident Rate} = (\text{Recurring incidents} \div \text{Total incidents}) \times 100$$

For example, if 8 out of 100 incidents are caused by previously identified weaknesses:

$$\text{Recurring Incident Rate} = 8\%$$

A declining recurring-incident rate indicates that lessons learned and corrective actions are effective.

F. Additional Useful KPIs

Other useful metrics include:

- Percentage of incidents detected automatically
- Percentage of incidents resolved within SLA
- Percentage of critical vulnerabilities patched within the required period
- Number of compromised accounts
- Number of affected systems
- False-positive rate
- Number of security incidents by severity
- Percentage of incident-response actions completed on time
- Mean Time to Contain (MTTC)
- Mean Time to Recover
- Number of overdue corrective actions
- Security-team training completion rate

G. KPI Example Dashboard

KPI	Current Result	Target	Interpretation
MTTD	45 min	< 20 min	Detection needs improvement
MTTR	60 min	< 30 min	Response efficiency needs improvement
Resolution Time	8 hrs	< 4 hrs	Recovery should be improved
Escalation Rate	15%	Risk-based	Review escalation quality
Recurring Incident Rate	10%	< 5%	Corrective actions need improvement
Critical Patch Compliance	85%	> 95%	Patch process requires improvement

The exact targets should be based on the organization's risk profile, incident severity, regulatory requirements, and operational capacity rather than using arbitrary universal values.

3. How KPIs Support Audit and Governance

A. Audit Support

KPIs provide measurable evidence that security processes are operating effectively. Auditors can review:

- Incident records
- Detection and response timestamps
- Escalation records
- Corrective-action registers
- Patch compliance
- Access reviews
- Incident-response exercises
- Policy updates

This creates an auditable trail showing what happened and how the organization responded.

B. Governance Support

Management can use KPIs to:

- Evaluate security-team performance.
- Allocate cybersecurity budgets.
- Identify high-risk weaknesses.
- Track compliance with security policies.
- Compare performance against organizational targets.

- Prioritize security investments.
- Demonstrate accountability.

For example, consistently high MTTD may justify investment in improved SIEM, EDR, threat detection, automation, or additional SOC resources.

C. Future Security Improvements

KPIs should not simply be reported; they should drive corrective actions.

For example:

High MTTD → Improve monitoring and detection

High MTTR → Improve response playbooks and automation

High recurring incidents → Perform stronger root-cause analysis

Low patch compliance → Improve vulnerability and patch management

High unauthorized-access incidents → Strengthen IAM and MFA

Delayed escalation → Improve severity classification and escalation procedures

Therefore, KPIs create a feedback mechanism between incident response and long-term security improvement.

Conclusion

A cybersecurity incident should be treated as an opportunity to strengthen the organization's overall security posture. A detailed post-incident investigation should reconstruct the timeline, identify the root cause and contributing factors, assess technical and business impact, and document lessons learned. The findings should then be translated into specific improvements to password management, access control, patch management, monitoring, and incident escalation policies.

At the same time, KPIs such as **MTTD, MTTR, incident resolution time, escalation rate, and recurring incident rate** provide management with measurable evidence of incident-response effectiveness. When these metrics are continuously monitored and connected to corrective actions, they support **audit, governance, accountability, risk reduction, and continuous improvement**. This transforms incident response from a reactive activity into a continuous security-improvement process.